

WHITE PLAINS HOSPITAL | VENDOR SECURITY QUESTIONNAIRE | MedBill Pro Solutions | April 2026

5 = Fully Met

4 =
Mostly

3 = Partially Met

2 =
Mostly

1 = Not
Met

0 = No Response

#

SECURITY QUESTION

Max
Score

VENDOR RESPONSE

Score
Given

Score
%

Gap?

ASSESSOR NOTES

ORGANIZATIONAL SECURITY

1

Does your organization have a formally documented Information Security Policy?

5

Yes — ISO 27001 aligned policy reviewed annually

5

100%

No

Strong. Policy is documented, approved, and regularly reviewed.

2

Is there a designated Chief Information Security Officer (CISO) or equivalent?

5

Yes — CISO appointed with dedicated security team of 8 staff

5

100%

No

Excellent. Dedicated security leadership in place.

3

Does your organization conduct annual security risk assessments?

5

Yes — annual risk assessments conducted and documented

5

100%

No

Compliant. Risk assessments are conducted and documented annually.

4

Have you had any data breaches or security incidents in the past 3 years?

5

One minor phishing incident in 2023 — contained within 4 hours, no PHI exposed

3

60%

YES

Acceptable. Incident was minor and handled promptly. Request incident report.

5

Do you carry cyber liability insurance?

5

Yes — \$5 million cyber liability coverage with AIG

5

100%

No

Strong. Adequate cyber insurance coverage confirmed.

6

Do you conduct annual security awareness training for all staff?

5

Yes — mandatory training with phishing simulations quarterly

5

100%

No

Excellent. Comprehensive training program with practical simulations.

DATA PROTECTION & PRIVACY

7

Do you have a documented data classification policy?

5

Yes — four-tier data classification policy in place

5

100%

No

Strong. Formal data classification aligns with HIPAA requirements.

8	Is all Protected Health Information (PHI) encrypted at rest?	5	Yes — AES-256 encryption applied to all PHI storage	5	100%	No	Compliant. AES-256 encryption meets HIPAA technical safeguard requirements.
9	Is PHI encrypted in transit between your systems and client systems?	5	Yes — TLS 1.3 enforced on all PHI transmissions	5	100%	No	Excellent. Modern TLS 1.3 encryption for all data in transit.
10	Do you have a documented data retention and disposal policy?	5	Yes — 7 year retention policy with certified destruction for disposal	5	100%	No	Compliant. Retention policy meets HIPAA 6-year minimum requirement.
11	Do you have a formal data breach response plan?	5	Yes — documented IRP with 72-hour notification procedures	5	100%	No	Strong. Breach response plan covers both HIPAA and GDPR notification timelines.
12	Do you limit employee access to PHI based on job role (minimum necessary)?	5	Yes — role-based access control with quarterly access reviews	5	100%	No	Compliant. Minimum necessary standard enforced through RBAC.
13	Is multi-factor authentication (MFA) required for all PHI system access?	5	Partially — MFA on primary systems. Legacy billing module not yet upgraded.	2	40%	YES	GAP IDENTIFIED. Legacy system lacks MFA. Require remediation timeline.
14	Do you conduct Privacy Impact Assessments for new systems handling PHI?	5	Yes — PIA conducted for all new systems before deployment	5	100%	No	Strong. Proactive privacy impact assessment process in place.
ACCESS CONTROL & IDENTITY							
15	Are all user accounts unique — no shared accounts permitted?	5	Yes — unique accounts required. Shared accounts prohibited by policy.	5	100%	No	Compliant. Unique user identification meets HIPAA Security Rule §164.312(a)(2)(i).
16	Do you have a formal process for onboarding and offboarding user access?	5	Yes — automated provisioning and deprovisioning linked to HR system	5	100%	No	Excellent. Automated offboarding reduces risk of orphaned accounts.

17	Are privileged accounts managed separately from standard user accounts?	5	Yes — PAM solution in place with just-in-time privileged access	5	100%	No	Strong. Privileged Access Management reduces insider threat risk.
18	Do you conduct quarterly user access reviews?	5	Yes — quarterly access certifications for all PHI systems	5	100%	No	Compliant. Regular access reviews meet HIPAA administrative safeguard requirements.
19	Are audit logs maintained for all PHI access and activity?	5	Yes — immutable audit logs retained for 7 years	5	100%	No	Excellent. Comprehensive audit logging with long-term retention.

NETWORK & INFRASTRUCTURE

20	Is your network segmented to isolate PHI systems from general network traffic?	5	Yes — PHI systems in dedicated VLAN with firewall controls	5	100%	No	Strong. Network segmentation reduces blast radius of potential breach.
21	Do you conduct regular vulnerability scanning of PHI systems?	5	Yes — weekly automated scans and quarterly manual penetration testing	5	100%	No	Excellent. Comprehensive vulnerability management program.
22	Do you have an intrusion detection or prevention system (IDS/IPS)?	5	Yes — enterprise IDS/IPS monitored 24/7 by SOC	5	100%	No	Strong. 24/7 SOC monitoring provides continuous threat detection.
23	Is there a patch management policy with defined timelines?	5	Yes — critical patches within 24 hours, high within 72 hours, medium within 30 days	5	100%	No	Compliant. Patch timelines align with industry best practice.
24	Do you have a tested disaster recovery and business continuity plan?	5	Yes — DR tested annually. RTO 4 hours, RPO 1 hour for PHI systems	5	100%	No	Excellent. Tested DR with aggressive RTO/RPO targets for PHI availability.
25	Is remote access to PHI systems restricted to VPN with MFA?	5	Yes — VPN with MFA required. Direct remote access to PHI prohibited.	5	100%	No	Strong. Remote access controls meet HIPAA technical safeguard requirements.

COMPLIANCE & CERTIFICATIONS

26	Do you hold a current SOC 2 Type 2 certification?	5	Yes — SOC 2 Type 2 report available. Last audit: November 2025.	5	100%	No	Excellent. SOC 2 Type 2 provides independent assurance of control effectiveness.
27	Are you HIPAA compliant and willing to sign a Business Associate Agreement?	5	Yes — HIPAA compliance program in place. BAA signed as standard practice.	5	100%	No	Compliant. BAA agreement in place meets HIPAA organizational requirements.
28	Have you undergone a third-party HIPAA assessment in the past 2 years?	5	Yes — external HIPAA assessment conducted Q3 2025. No critical findings.	5	100%	No	Strong. Recent independent HIPAA assessment with clean results.
29	Do you conduct background checks on all employees with PHI access?	5	Yes — criminal background checks for all staff before PHI access granted	5	100%	No	Compliant. Background check process meets workforce clearance requirements.
30	Do you have a subcontractor management program for fourth-party risk?	5	Partially — primary subcontractors reviewed but no formal fourth-party program	2	40%	YES	GAP IDENTIFIED. Fourth-party risk not formally managed. Requires improvement.
PHYSICAL SECURITY							
31	Are data centers and server rooms protected with physical access controls?	5	Yes — biometric access, CCTV, and security guards at all data center locations	5	100%	No	Excellent. Multi-layered physical security controls at all PHI processing locations.
32	Are physical media containing PHI subject to secure disposal procedures?	5	Yes — NIST 800-88 certified data destruction for all physical media	5	100%	No	Strong. NIST-compliant media disposal process confirmed.
33	Do you have environmental controls protecting PHI systems (fire, flood, power)?	5	Yes — Tier 3 data center with redundant power, cooling, and fire suppression	5	100%	No	Excellent. Tier 3 data center provides high availability and environmental protection.
VENDOR & CONTRACT MANAGEMENT							
34	Do you maintain a complete inventory of all subcontractors handling PHI?	5	Yes — formal subcontractor register with annual review process	4	80%	YES	Good. Subcontractor register maintained but fourth-party risk program incomplete.

35	Do you require all subcontractors handling PHI to sign BAAs?	5	Yes — BAA required as contractual condition for all PHI-handling subcontractors	5	100%	No	Compliant. BAA flow-down requirements protect White Plains Hospital.
36	What is your average response time to a client security incident notification?	5	Within 24 hours for all security incidents. PHI breaches within 4 hours.	5	100%	No	Excellent. Rapid incident notification timelines exceed HIPAA requirements.
TOTAL ASSESSMENT SCORE		180		171	95%	4 gaps	